SHYGON — P0 INCIDENT RUNBOOK (print · A4 · keep by the on-call phone)

P0 = credible, severe, active or imminent risk. Scope unknown but severe impact credible → **declare provisionally P0**. Triggers: security compromise · cross-tenant exposure · auth/authz failure · sensitive-data exposure · data loss/corruption · **resolver down (every card dead)** · safety (Rescue) failure · payment integrity · destructive change · mass Tap redirection.

Step	Target	Do
01 Declare	T+0	Open P0 record (ID `P0-YYYYMMDD-NN`) · preserve evidence · set legal hold (K14) if personal data · notify Incident Lead in the **out-of-band channel**
02 Acknowledge	≤ 5 min	Human ack. None? Fallback: Designated Lead → Domain Owner → Architect/Release Owner → Product Owner → Authorized Responder
03 Accountable Owner	≤ 10 min	One A per decision domain. **Incident Lead ≠ Accountable Owner.**
04 Specialists	≤ 15 min	Engage only who's needed; record R/A/C/I
05 Contain	plan ≤ 20 · act ≤ 30 min	Use **only** switches your role may pull (table below). No unrelated changes.
06 Communicate	every 30 min	CONFIRMED / SUSPECTED / UNKNOWN · next update time · external text approved by Product Owner
06b Regulatory	≤ 60 min	Data Owner + counsel: CERT-In (6 h), DPDP breach, Razorpay, org contracts
07 Conflict	—	STOP → identify decision → identify A → resolve → document → proceed
08 Handoff	ack ≤ 10 min	No silent handoffs. No ack → next fallback.
09 Recover	direction ≤ 60 min	Roll back / fix forward / isolate / disable / restore / investigate / escalate — risk, rollback, tests, security, data, approvals, verification plan first
10 Verify	—	Deploy succeeded ≠ recovered. Run the playbook's verification tests.
11 Close	—	Contained · recovered · verified · security/data reviewed · monitoring stable · A confirms · timeline · follow-ups
12 Review	≤ 3 business days	Blameless review → tracked actions → institutional memory

CONTAINMENT SWITCHES (DOC 13 §7) — WHO MAY PULL

K	Switch	Security	Release	Data	Eng	Product	Responder (P0 only)
K1	Resolver maintenance page	✔	✔		✔	✔	✔ if IL unreachable ≥ 5 min
K2	Revoke one device / persona / account	✔					support admin (single account)
K3	Disable a public endpoint	✔	✔		✔		✔
K4	Freeze customer writes	✔		✔			
K5	Pause checkout	✔	✔			✔	✔
K6	Hold fulfilment	✔		✔			
K7	Pause a notification channel	✔	✔		✔		
K8	Revoke sessions (all)	✔					
K9	Deactivate an admin	✔				Founder	
K10	Rotate a secret	✔	✔				
K11	Roll back deploy		✔		✔ (RO unreachable)		
K12	Stop migration			✔			stop only
K13	Purge edge cache	✔	✔		✔		✔
K14	Legal hold	✔		✔			
K16	Freeze route changes	✔	✔				✔
K19	Disable an AI agent	✔	✔		✔	✔	✔

Break-glass SQL: `scripts/ops/break-glass/` · Secret rotation: `RUNBOOK-secrets.md` · Playbooks PB-1…PB-11: `docs/runbooks/`

CONTACTS (FILL IN AND KEEP CURRENT)

Role	Name	Phone
Incident Lead (primary / secondary)		
Security Owner		
Data Owner		
Release Owner		
Principal Architect		
Product Owner		

Out-of-band channel: _____ · Paging service: _____ · Status page: _____ Supabase support: _____ · Netlify/Vercel: _____ · Razorpay: _____ · Registrar: _____

LIVE P0 STATUS

P0 ID _____ · Start _____ · Elapsed _____ · IL _____ · A _____ · State _____ · Impact _____ · Containment _____ · Risk _____ · Next decision _____ · Next update _____

10-second check before any material action: who owns it? what's happening? what evidence? what risk? is this action authorized for me? who must approve? how will we verify? **If any answer is unknown → STOP, surface the gap, escalate.**